

NARRATIVA EXPLICATIVA GQM + PRAGMATIC

Cómo Conectar Objetivos Nacionales, Preguntas Inteligentes y Métricas que de Verdad Sirven

Versión 1.0 — Abril 2026

"No es que falten métricas en ciberseguridad; sobran. Lo que falta es una teoría razonable para decidir cuáles merecen nuestro tiempo, nuestro presupuesto y, ya puestos, nuestra fe."

I. DEL "MEDIR PORQUE HAY DATOS" AL "MEDIR PORQUE HAY OBJETIVOS"

Durante años, el discurso de la ciberseguridad se ha llenado de dashboards exuberantes: gráficas de colores, contadores de eventos procesados, mapas de calor que parecen obras de arte generativo. El problema no es la falta de datos, sino la abundancia de métricas que no responden a ninguna pregunta importante.

El enfoque **Goal-Question-Metric (GQM)** se inventó precisamente para huir de esa numerología tecnológica. Basili y Weiss observaron que la manera habitual de "elegir" métricas —mirar qué datos genera el sistema y decidir cuáles parecen interesantes— conduce a programas de medida que consumen recursos y explican poco[cite:129][cite:138]. La solución fue obvia y radical: invertir el orden.

1. Primero, el objetivo (Goal): ¿Qué queremos conseguir o entender?
2. Después, las preguntas (Questions): ¿Qué deberíamos preguntarnos para saber si nos acercamos a ese objetivo?
3. Solo al final, las métricas (Metrics): ¿Qué podemos medir para responder a esas preguntas?

La virtud de GQM es su insistencia en que ningún indicador técnico es inocente: o responde a una pregunta relevante o es ruido. La virtud práctica es que obliga a formular de forma explícita conexiones como esta: *"Queremos reducir el impacto de ransomware en las infraestructuras críticas (Goal). Para ello necesitamos saber cuánto tardamos en detectarlo (Question). Por tanto medimos el MTTD (Metric)."*

En el contexto español —con un incremento del 26% en incidentes gestionados por INCIBE en 2025, una inversión nacional sin precedentes y una normativa en convergencia hacia NIS2, ENS y DORA— esta disciplina deja de ser una exquisitez metodológica y pasa a ser un requisito de mera supervivencia intelectual.

II. PRAGMATIC: UN FILTRO PARA MÉTRICAS EN UN MUNDO CON DEMASIADAS

Una vez alineadas las métricas con objetivos y preguntas gracias a GQM, surge el segundo problema: **¿son buenas métricas?** No basta con que sean coherentes; deben ser útiles. Aquí entra en escena el enfoque **PRAGMATIC Security Metrics**, acuñado por Brotby e Hinson[cite:130][cite:131][cite:136][cite:142].

PRAGMATIC propone nueve criterios para evaluar cada métrica potencial:

- Predictive: ¿Dice algo significativo sobre el futuro antes de que sea demasiado tarde?
- Relevant: ¿Le importa esta métrica a quien toma decisiones?
- Actionable: ¿Sugiere acciones concretas o se limita a describir la catástrofe?
- Genuine: ¿Se basa en datos fiables, no "maquillados"?
- Meaningful: ¿Es comprensible sin doctorado en estadística?
- Accurate: ¿Tiene suficiente precisión para la decisión que soporta?
- Timely: ¿Llega a tiempo para actuar?
- Independent: ¿Está libre de conflictos de interés evidentes?
- Cheap: ¿Cuesta menos obtenerla que el valor de la decisión que permite?

Cada criterio se puntúa típicamente de 0 a 10. Una métrica con 80/90 es un diamante; una con 30/90 es, como poco, sospechosa. La belleza del enfoque es que hace explícitos juicios que antes se tomaban a ojo: de repente, decir "esta métrica no nos sirve" deja de ser una intuición vaga y se convierte en una evaluación argumentada.

Aplicado al ecosistema MSS, PRAGMATIC nos ayuda a separar la métrica que impresiona al proveedor en su presentación —"hemos procesado 27.000 millones de eventos este mes"— de la métrica que cambia una decisión —"nuestro MTDD de incidentes críticos ha pasado de 8 horas a 45 minutos".

III. TRAZABILIDAD DESDE LA ESTRATEGIA NACIONAL HASTA EL LOG DEL FIREWALL

Uno de los retos más sutiles en ciberseguridad es explicar cómo una decisión aparentemente técnica —por ejemplo, refinar las reglas de un SIEM— está relacionada con un objetivo político —por ejemplo, reforzar la ciberresiliencia nacional. El enfoque **GQM+Strategies** extiende GQM precisamente para garantizar esta trazabilidad vertical[cite:129][cite:138].

Veamos la cadena, de arriba abajo:

4. Objetivo nacional (G0.1): "Reducir en un 50% el impacto de incidentes graves en infraestructuras esenciales en 5 años".
5. Objetivo organizacional (G-ORG): "Reducir en un 30% los incidentes críticos que afectan a nuestros servicios esenciales en 3 años".
6. Objetivo de servicio MSS (G-DR2): "Conseguir antes de fin de año un MTDD < 1h y un MTTR < 24h para incidentes críticos".
7. Preguntas (Q): "¿Cuál es nuestro MTDD actual? ¿Qué porcentaje de incidentes se detecta automáticamente?"
8. Métricas (M): MTDD, MTTR, %detección automática, etc.

En esta cadena, un simple cambio de regla en el SIEM, que reduce falsos positivos y mejora el MTDD, deja de ser un micro-ajuste técnico y pasa a ser una contribución concreta a un objetivo estratégico. La métrica MTDD, evaluada además con PRAGMATIC, se convierte en un hilo que cose la estrategia nacional con la realidad de un analista en el SOC a las 3:17 de la madrugada.

IV. UNA PREGUNTA INCÓMODA: ¿QUÉ MÉTRICAS SOBRAN EN NUESTROS DASHBOARDS?

El marco GQM+PRAGMATIC no solo ayuda a añadir métricas buenas; también funciona como detector de métricas ornamentales. Las típicas víctimas de este escrutinio son las métricas de *actividad* sin conexión clara con objetivos:

- "Número de alertas procesadas"
- "Volumen total de logs ingeridos"
- "Número de tickets cerrados por mes"

Aplicando GQM, la primera pregunta honesta es: **¿para qué queremos esta métrica?** Si la respuesta no pasa de un tímido "para demostrar que trabajamos mucho", estamos frente a un candidato idóneo para el reciclaje.

Aplicando PRAGMATIC, la sentencia suele ser rápida: son métricas poco predictivas, marginalmente relevantes para el negocio, escasamente accionables y a menudo poco significativas para la Alta Dirección. Dicho de manera literaria: son fuegos artificiales de datos.

El objetivo del marco no es dejar el dashboard vacío, sino quedarse con pocas métricas que cumplan dos condiciones:

9. Responden a preguntas que derivan de objetivos explícitos (GQM).
10. Han superado un examen razonablemente severo de utilidad práctica (PRAGMATIC).

V. EJEMPLOS QUE CAMBIAN LA CONVERSACIÓN

Ejemplo 1 — MTTD vs. "Incidentes gestionados"

En muchas organizaciones, el informe al Consejo incluye un gráfico creciente del número de incidentes gestionados. La interpretación optimista es: *"somos cada vez más capaces de detectar y gestionar incidentes"*. La pesimista es igualmente plausible: *"nos atacan más y llegamos tarde"*.

Con un enfoque GQM+PRAGMATIC, la métrica de "incidentes gestionados" revela su ambigüedad: es poco predictiva, apenas accionable y difícil de interpretar sin contexto. En cambio, el MTTD — correctamente definido, medido y puntuado— cambia la conversación:

"Hemos reducido el MTTD de 8 horas a 1 hora en un año. Esto nos acerca a la ventana de notificación NIS2 y reduce la probabilidad de impacto grave."

De golpe, el foco se mueve del volumen a la calidad de la respuesta.

Ejemplo 2 — % MFA vs. "usuarios concienciados"

Las encuestas de concienciación, con sus porcentajes de empleados que "saben lo que es un phishing", tienen su gracia, pero el regulador y el atacante se preocupan por otras cosas: ¿hay MFA en las cuentas que importan?

Una métrica GQM+PRAGMATIC bien construida del porcentaje de cuentas con MFA obligatorio puntúa alto en casi todos los criterios: predice reducción de compromisos, es relevante, accionable, precisa, oportuna e independiente si se basa en datos del proveedor de identidad. Además, alinear esa métrica con NIS2 Art. 21.2 j) permite traducirla directamente a riesgo de sanción.

Ejemplo 3 — Crypto-Agility Score vs. "tenemos TLS en todas partes"

"Tenemos TLS" fue un buen argumento hace una década. En la era de la criptografía postcuántica, es un mínimo de cortesía. El Crypto-Agility Score, aunque joven y aún imperfecto, apunta hacia una pregunta mucho más profunda: *"¿cuán dolorosa será nuestra migración a PQC cuando sea inevitable?"*

Aunque su puntuación PRAGMATIC no es tan alta como MTDD o ACR, introduce una dimensión temporal que los SLAs tradicionales ignoran: **el coste futuro de no poder cambiar justo cuando el mundo lo exige.**

VI. LO QUE GQM + PRAGMATIC NO HACE (Y ES IMPORTANTE SABER)

Ningún marco, por elegante que sea, está exento de limitaciones:

- No elimina la necesidad de juicio experto: Puntuar una métrica en "Genuina" o "Independiente" exige conocer el contexto cultural y organizativo. Un PRAGMATIC 80/90 mal interpretado puede tranquilizar injustificadamente.
- No sustituye al cumplimiento formal: Una métrica bien puntuada no exime de cumplir los requisitos literales de ENS, NIS2 o DORA. El mapeo normativo sirve para alinear, no para negociar con el regulador.
- No garantiza estabilidad eterna: La relevancia y la accionabilidad son funciones del tiempo. Una métrica excelente hoy puede volverse irrelevante si la tecnología o las amenazas cambian (piense en métricas centradas en perímetros cuando el perímetro desaparece).

El marco está diseñado para ser revisado. GQM requiere actualizar objetivos y preguntas; PRAGMATIC pide recualificar criterios a la luz de nuevas evidencias. La revisión no es un fallo del sistema: es su respiración.

VII. EPÍLOGO: EL LUJO DE SABER QUÉ IGNORAR

En un mundo con más datos que nunca, la ventaja competitiva no reside en quien ve más, sino en quien sabe qué ignorar sin remordimientos. El lujo intelectual del marco GQM + PRAGMATIC consiste precisamente en esto: dotar a los responsables de ciberseguridad de una excusa metodológicamente respetable para dejar de alimentar métricas que solo sirven para justificar la existencia de herramientas.

Si, tras aplicar este marco, su cuadro de mando MSS termina con diez métricas en lugar de cincuenta, y si esas diez están sólidamente conectadas con objetivos nacionales, preguntas inteligentes y decisiones accionables, habrá ocurrido algo notable: habrá menos gráficos, pero más gobierno.

Y en ciberseguridad, como en casi todo, menos es más cuando lo que se elimina es ruido.

Narrativa Explicativa GQM + PRAGMATIC — Versión 1.0 · Abril 2026

Basada en: Basili & Weiss — Goal–Question–Metric[cite:129][cite:132][cite:138][cite:141], Brotby & Hinson — PRAGMATIC Security Metrics[cite:130][cite:131][cite:136][cite:142], aplicaciones GQM a ciberseguridad[cite:134], revisión académica sobre criterios PRAGMATIC[cite:139].